

SICHERHEIT ALS LIEFERBEDINGUNG:

DER MITTELSTAND IN DER KRITIS-PFLICHT

CYBERSICHERHEIT Das KRITIS-Dachgesetz rückt die physische Sicherheit der zentralen Versorgungsstrukturen, also der kritischen Infrastruktur, in den gesetzlichen Fokus. Während die Regulierung auf den ersten Blick vor allem große Energie- und Wasserversorger betrifft, strahlen die Anforderungen über die gesamte Lieferkette bis in den Mittelstand aus. Für mittelständische Unternehmen ist es daher entscheidend, eigene Abhängigkeiten frühzeitig zu prüfen.

Beim Thema Sicherheit für die kritische Infrastruktur (kurz KRITIS) geht es derzeit meist um zwei Gesetze: die NIS2-Richtlinie, eine EU-weite Vorgabe zur Stärkung der Cybersicherheit, und das deutsche KRITIS-Dachgesetz, das sich im Gegensatz dazu auf den physischen Schutz baulicher Anlagen, zum Beispiel gegen Naturkatastrophen oder Sabotage, auf die Kernbereiche der staatlichen Grundversorgung konzentriert. Das hört sich für einen Mittelständler zunächst einmal sehr weit weg an. Doch Markus Weidenauer, Geschäftsführer der SecCon Group mit jahrzehntelanger operativer Erfahrung im Sicherheitsmanagement, erklärt die Dringlichkeit für mittelständische Unternehmen: „Sie werden die Auswirkungen spüren, denn Sicherheit und Resilienz lassen sich in hochvernetzten Versorgungssystemen nicht isoliert betrachten. Vielmehr hängen Prozesse, Lieferketten und Infrastrukturen eng zusammen.“

**DESHALB IST DAS KRITIS-DACHGESETZ
AUCH FÜR KMU RELEVANT:**

1. Kritische Infrastrukturen funktionieren nur als Gesamtsystem

Energie, Wasser, Telekommunikation, Logistik oder Lebensmittelversorgung sind miteinander verflocht-

ten. Fällt ein Sektor aus, hat das unmittelbare Auswirkungen auf andere Bereiche des täglichen Lebens. „Selbst wenn ein Unternehmen formal nicht unter die KRITIS-Schwellenwerte fällt, kann es Teil einer kritischen Liefer- oder Versorgungsstruktur sein“, so Weidenauer.

2. Druck durch die Lieferkette

Große KRITIS-Betreiber wie zum Beispiel Energieversorger sind gesetzlich verpflichtet, ihre gesamte Wertschöpfungskette abzusichern – und geben diese Anforderungen an ihre mittelständischen Zulieferer weiter, für die Sicherheitszertifizierungen somit zur Bedingung für eine weitere Zusammenarbeit werden. Mittelständische Unternehmen könnten daher zunehmend mit Anforderungen konfrontiert werden, etwa in Form von Sicherheitsnachweisen, Risikoanalysen oder organisatorischen Schutzmaßnahmen.

3. Der All-Gefahren-Ansatz durch Kaskadeneffekte

In hoch vernetzten Systemen kann der Ausfall eines mittelständischen Spezialdienstleisters ganze Sektoren wie das Gesundheitswesen oder die Wasserversorgung lahmlegen. Bislang lag der Fokus vieler Sicherheitsregulierungen auf der Cyber- und IT-Sicherheit. Das neue Gesetz – seit 17. März 2026 offiziell in Kraft – verfolgt dagegen einen sogenannten All-Gefahren-Ansatz. Neben digitalen Angriffen werden auch physische Bedrohungen, Sabotageakte, Naturereignisse oder organisatorische Risiken berücksichtigt. Für Unternehmen bedeutet das: Sicherheit muss ganzheitlicher gedacht werden. „Technische Schutzmaßnahmen spielen eine ebenso große Rolle wie organisatorische Strukturen, klare Verantwortlichkeiten, Notfall- und Krisenpläne sowie geschulte Mitarbeitende“, ordnet Weidenauer ein.

4. Persönliche Haftung der Geschäftsführung

Wie beim NIS2-Umsetzungsgesetz haften Geschäftsleitungen im Schadensfall vermehrt persönlich für Versäumnisse bei der Risikoanalyse und der Implementierung von Schutzmaßnahmen. Anders als bisher müssen Betreiber kritischer Infrastrukturen nicht nur nachweisen können, dass sie angemessene Maßnahmen zur Risikovorsorge und Resilienz umgesetzt haben, es bestehen auch Meldepflichten. Verstöße können mit Bußgeldern sanktioniert werden.

5. Resilienz wird zum Wettbewerbsfaktor

Neben regulatorischen Anforderungen spielt auch die wirtschaftliche Perspektive eine zentrale Rolle. Gerade in Zeiten geopolitischer Spannungen und verflochtener Lieferketten stärken Unternehmen, die frühzeitig auf Risikoanalysen, Sicherheitsstrukturen und Krisenmanagement setzen, ihre eigene Stabilität.

6. Versicherbarkeit und Finanzierung

Finanzinstitute und Versicherer bewerten die Widerstandsfähigkeit von Unternehmen heute nicht mehr als freiwilliges Extra, sondern als harten Risikofaktor. Versicherungsunternehmen nutzen beispielsweise den Nachweis von Resilienzmaßnahmen, um ihr eigenes Risiko zu kalkulieren, etwa mit Blick auf Deckungsfähigkeit, Prämiengestaltung oder Schadensregulierung. Für Banken wiederum ist die Resilienz eines Unternehmens direkt mit dessen Bonität und Ausfallwahrscheinlichkeit verknüpft. Das betrifft unter anderen das Risiko-Rating, Basel-III/IV-Anforderungen oder ESG-Kriterien als Treiber.

KURZCHECK: WER IST BETROFFEN?

Um zu prüfen, ob ein Unternehmen unter das KRITIS-Dachgesetz und die damit verknüpfte NIS2-Richtlinie fällt, bietet sich eine schrittweise Prüfung anhand der gesetzlichen Kriterien an. Denn seit Inkrafttreten der neuen Regelungen Anfang 2026 sind die Schwellenwerte und Sektoren präziser definiert. Wer betroffen ist, muss sich spätestens bis zum 17. Juli 2026 auf dem Meldeportal des Bundesamts für Bevölkerungsschutz und Katastrophenhilfe (BBK) sowie dem des Bundesamts für Sicherheit in der Informationstechnik (BSI) registrieren. ↙

HILFSMITTEL & ANLAUFSTELLEN

- **BSI-Betroffenheitsprüfung:** Das Bundesamt für Sicherheit in der Informationstechnik (BSI) bietet eine anonyme NIS2-Betroffenheitsprüfung an, die als Orientierung dient
- **Sektorspezifische Verordnungen (BSI-KritisV):** Die Anhänge der KRITIS-Verordnung zeigen genaue Berechnungsformeln für die jeweiligen Sektoren
- **Bundesamt für Bevölkerungsschutz und Katastrophenhilfe (BBK):** Zukünftige Aufsichtsbehörde für die physische Resilienz im Rahmen des KRITIS-Dachgesetzes
- **Bundesverband zum Schutz Kritischer Infrastrukturen (BSKI):** Netzwerk für den Wissensaustausch zwischen Wirtschaft und Politik



MARKUS WEIDENAUER
ist geschäftsführender Gesellschafter der SecCon Group aus dem bayerischen Unterschleißheim